

Do You Have a Strategy to Manage Open Source Risks in Web Applications?

As per an IDC report, every organisation is a software company today. Staying competitive depends on how fast your business can transform, and embrace new tools and technology. For high-performing organisations, this means open source software is now a matter of 'when', and not 'if' it should be employed. But there are risks involved in the use of vulnerable open source software components which, thankfully, can be managed easily with the right strategy.

Use of open source components has become an integral part of software development today.

A key advantage is the significant reduction in cost and time of development, which frees up engineers to focus on deeper challenges of their products while accelerating the time to market. With the Covid-led digital transformation of businesses, the adoption of open source software is going to increase all the more.

While use of open source software brings benefits and opportunities, it has risks and challenges too. An important challenge that comes along is the security of these components and, eventually, the security of the products that make use of them. For example, a new critical vulnerability, named Log4Shell, was recently disclosed in a few versions of the worldwide popular Log4j library exposing many applications to potential attacks.

The widespread use of open source components requires that we take a more proactive approach to open source management to make sure the software products that we are building do not contain vulnerable components. As these security vulnerabilities are disclosed publicly, they are easily exploitable. The OWASP's Top Ten list of Web application security risks was updated in 2017 to cover this risk; it has now moved up the list and is referred to as 'Vulnerable and Outdated Components'.

Managing open source risk in applications

One might say that the easiest way to reduce the risk is to avoid using components created by others. This could be the safest option, but it's quite unrealistic today as it deprives one of the large pool of ready-to-use components that can foster the speed of development, which is paramount to stay competitive.

In view of this, it is important to implement a good open source strategy to set and enforce policies that are automated throughout the SDLC. Tools and methods should be put in place that can automatically discover open source dependencies (direct as well as transitive) in applications, cross-check them against published vulnerabilities, trigger alerts when risks are identified and even block the release!

Elements of an open source management programme

A few key elements for building effective processes and strategies for safe consumption of open source are shared below.

